ROCKLEDGE BENEFITS ADMINISTRATORS — AI RISK ASSESSMENT (NIST AI RMF MAP / MEASURE)

Risks assessed against NIST AI RMF trustworthiness characteristics and AI 600-1 GenAI risk categories | EU AI Act as amended by Reg. (EU) 2026/1744 (in force 27 Jul 2026) | Assessment date: 2026-08-05 | Fictional organization. Created for portfolio demonstration purposes.

Risk ID	AI System	AI RMF Trustworthiness Characteristic	GenAI Risk Category (AI 600-1)	Risk Description	Harm Type	Affected Population	Inherent Likelihood	Inherent Impact	Inherent Score	Inherent Level	Existing Controls	Residual Likelihood	Residual Impact	Residual Score	Residual Level	Treatment	Planned Controls / Actions	AI RMF Function	Owner	Target Date
AIR-001	AI-001 ClaimDesk	Fair — with harmful bias managed	—	Model trained on historical adjudication data may encode past disparities; denial recommendations may differ by protected characteristic proxied through ZIP code and plan type.	Discriminatory outcome; regulatory	Members in 3 EU plans + all US plans	4	5	20	Critical	No fairness testing performed; adjuster confirms each recommendation but override rate is 3%, indicating automation bias.	3	5	15	Critical	Mitigate	Commission disparate-impact analysis across protected classes; establish fairness metrics and thresholds; retrain or reweight if thresholds breached; document per EU AI Act Art. 10 data governance.	Measure	VP Claims Operations	2026-09-23
AIR-002	AI-001 ClaimDesk	Accountable & Transparent	—	No documented explanation for individual recommendations; members denied benefits cannot receive a meaningful reason beyond the adjuster's note.	Rights; regulatory	Members receiving adverse decisions	4	4	16	Critical	Adjuster free-text rationale field (inconsistently completed).	3	4	12	High	Mitigate	Implement per-decision feature attribution (SHAP or equivalent) surfaced to adjuster; require structured rationale; align to adverse-action notice requirements.	Manage	VP Claims Operations	2026-10-21
AIR-003	AI-001 ClaimDesk	Valid & Reliable	—	Model performance drift as plan rules and provider coding change; no monitoring of live accuracy versus training baseline.	Financial; member harm	All adjudicated claims	3	4	12	High	Annual retraining; no in-production monitoring.	2	4	8	Medium	Mitigate	Deploy drift monitoring on input distributions and outcome rates; define retraining triggers; monthly performance report to model owner.	Measure	Head of Data Science	2026-09-21
AIR-004	AI-001 ClaimDesk	Accountable & Transparent	—	If ClaimDesk is High-Risk under Annex III, it operates for 3 EU client plans without conformity assessment, technical documentation, or database registration. Classification is contested: Annex III(5)(a) covers systems used by or on behalf of public authorities for essential public assistance benefits and (5)(c) covers insurance risk/pricing — neither cleanly covers private claims adjudication.	Regulatory (EU AI Act); contractual	Rockledge; EU clients	4	5	20	Critical	None specific to AI Act. Digital Omnibus (Reg. 2026/1744, in force 27 Jul 2026) moved the Annex III deadline to 2 Dec 2027, creating runway that did not exist a month ago.	4	5	20	Critical	Mitigate	Obtain written counsel determination on Annex III applicability by 23 Sep 2026 — this is the gating question. Proceed with fairness and explainability work regardless, since it is required on its merits. See Decision Memo for both classification outcomes.	Govern	General Counsel + VP Claims	2026-09-23 (counsel determination)
AIR-005	AI-004 Resume Screener	Fair — with harmful bias managed	—	Third-party ranking model with undisclosed training data; vendor declines to provide bias audit results; Dublin recruiting creates EU high-risk exposure and NYC roles trigger Local Law 144.	Discriminatory outcome; regulatory	Job applicants	4	5	20	Critical	Recruiter reviews top 20 only — candidates ranked 21+ never seen by a human.	4	5	20	Critical	Mitigate (pause)	Pause pilot. Require vendor bias audit report and Art. 13 transparency documentation as condition of resumption. If unavailable, terminate. Independent NYC LL144 audit if resumed for NYC roles.	Govern	VP People	2026-08-21
AIR-006	AI-002 Chatbot	Valid & Reliable	Confabulation	LLM generates confident but incorrect coverage answers; member acts on wrong deductible or network information.	Financial harm to member; reputational	Members using chatbot	4	3	12	High	RAG grounding on plan docs; no output verification; escalation button.	3	3	9	Medium	Mitigate	Implement grounded-citation requirement (answer must cite plan document section); confabulation test suite run on release; weekly sample audit of coverage answers; auto-escalate on low-confidence.	Measure	Director of Member Services	2026-09-23
AIR-007	AI-002 Chatbot	Accountable & Transparent	Human-AI Configuration	Members not clearly informed they are interacting with AI. Art. 50 transparency duties were expressly NOT deferred by the Digital Omnibus and applied from 2 Aug 2026 — this obligation is live now, unlike the Annex III high-risk duties.	Regulatory (AI Act Art. 50 transparency); trust	Members using chatbot	5	2	10	High	Small footer text.	2	2	4	Low	Mitigate	Prominent disclosure at session start; persistent AI indicator; easy path to human. Lowest effort item in the register and the only one already past its legal deadline. Do this first.	Manage	Director of Member Services	2026-08-21 (Art. 50 duty already applied 2026-08-02)
AIR-008	AI-002 Chatbot	Secure & Resilient	Information Security	Prompt injection via member-submitted text could extract system prompt or induce off-policy responses; RAG index includes documents with internal notes.	Data exposure; abuse	Rockledge; members	3	4	12	High	Azure content filters (default).	2	3	6	Medium	Mitigate	Red-team with OWASP LLM Top 10 test cases; scrub RAG index to member-facing documents only; input/output filtering; log and alert on injection signatures.	Measure	CISO	2026-09-23
AIR-009	AI-007 M365 Copilot	Privacy-Enhanced	Data Privacy	Copilot indexes SharePoint libraries containing PHI; users can surface member records they lack a need to know via natural-language query.	Privacy breach (HIPAA); regulatory	Members; Rockledge	4	5	20	Critical	SharePoint permissions (over-broad in legacy sites).	2	4	8	Medium	Mitigate	Restrict Copilot semantic index from PHI-classified sites; sensitivity labels + DLP for AI-generated content; access recertification on legacy libraries first.	Manage	CIO	2026-09-21
AIR-010	AI-009 Shadow AI	Privacy-Enhanced	Data Privacy	Staff pasting member data into consumer AI tools; no contractual protection, potential training-data ingestion.	Privacy breach; regulatory	Members	5	4	20	Critical	None.	2	3	6	Medium	Mitigate	AI acceptable use policy; CASB block on consumer AI endpoints; sanctioned enterprise alternative (AI-007) with data protections; awareness campaign; monitor CASB for residual usage.	Govern	CISO	2026-08-25
AIR-011	AI-003 Fraud Detector	Explainable & Interpretable	—	Vendor model flags claims with no reason code; SIU cannot explain to providers why payment was delayed; risk of unfair provider treatment.	Provider relations; potential regulatory	Providers; members with delayed claims	3	3	9	Medium	SIU reviews every flag before action.	2	3	6	Medium	Accept (with monitoring)	Request reason-code feature from vendor at renewal; track flag-to-confirmed-fraud rate by provider type quarterly to detect systematic skew. Human review already prevents automated adverse action.	Measure	Director of SIU	2026-12-22
AIR-012	Program-wide	Accountable & Transparent	—	No AI governance function, policy, or accountable executive; decisions about AI use made ad hoc by business units.	Organizational; all AI risks compound	Rockledge	5	4	20	Critical	None.	2	3	6	Medium	Mitigate	Establish AI Governance Committee (chair: General Counsel; members: CISO, CIO, Chief Actuary, VP People, Compliance); adopt AI policy; assign system owners; quarterly review cadence. Foundation for ISO/IEC 42001 alignment.	Govern	General Counsel	2026-08-25

COVERAGE BY NIST AI RMF TRUSTWORTHINESS CHARACTERISTIC

Which characteristics the register addresses, and how many risks each carries. Gaps in coverage are as informative as high counts.

Characteristic	# Risks	Highest Residual Level	Note
Valid & Reliable	3	Medium	Performance, accuracy, drift
Safe	0	—	Physical/psychological safety — no direct exposure in this inventory
Secure & Resilient	1	Medium	Adversarial robustness, prompt injection
Accountable & Transparent	4	Critical	Documentation, disclosure, governance
Explainable & Interpretable	1	Medium	Reason codes, attribution
Privacy-Enhanced	2	Medium	Data minimization, PHI exposure
Fair — with harmful bias managed	2	Critical	Disparate impact

METHOD & LIMITATIONS

Framework basis	NIST AI RMF 1.0 organizes AI risk into four functions (Govern, Map, Measure, Manage) and seven trustworthiness characteristics. Each risk is tagged to the characteristic it threatens and the function that owns its treatment. Generative-AI risks additionally reference NIST AI 600-1's twelve GenAI risk categories (confabulation, data privacy, information security, human-AI configuration, etc.).
Why tag to characteristics	It exposes coverage gaps. A register with eight fairness risks and zero security risks tells you the assessors' expertise, not the organization's exposure. The Trustworthiness Coverage tab is the check.
Scoring	5x5 qualitative, likelihood × impact. Ordinal, not cardinal — same limitation as any risk matrix. Adequate for prioritizing thirteen risks; inadequate for comparing spend across them. Impact anchored to harm type: a discriminatory-outcome risk at 5 is a different kind of severe than a financial risk at 5.
What is different about AI risk	Three things. (1) Harms are frequently to third parties — members, applicants — rather than to the organization, so the risk owner and the harmed party diverge. (2) Bias and drift are emergent: the system can be compliant at deployment and non-compliant six months later with no code change. (3) Human oversight is often nominal — a 3% override rate on AI-001 means the human is ratifying, not reviewing. Automation bias is itself a risk.
Relationship to the inventory	Every risk maps to an AI ID in the AI System Inventory. AIR-012 (no governance function) is program-wide and is the root cause behind several system-specific risks.
Relationship to the decision	AIR-004 and AIR-005 are the two risks that cannot be treated by controls alone — they require a business decision about whether to continue the use case. Those decisions are documented in the accompanying memo, not here.
Regulatory status as assessed	The Digital Omnibus on AI (Regulation (EU) 2026/1744) was published in the Official Journal on 24 July 2026 and entered into force on 27 July 2026. It defers Annex III standalone high-risk obligations from 2 August 2026 to 2 December 2027, and Annex I embedded high-risk systems to 2 August 2028. It does NOT defer Article 50 transparency duties, the Article 5 prohibitions, or GPAI provider obligations. The deferral is therefore selective, and treating it as a blanket extension is the error to avoid.
Why the deferral does not red	Two reasons. First, the one obligation that is live now — Art. 50 transparency, AIR-007 — is the one we had not met. Second, AIR-001 (encoded bias in denial recommendations) has no compliance date attached to it. The model either discriminates or it does not, and we currently cannot say which. Deadlines govern enforcement, not harm.
Contested classification	AIR-004 turns on whether ClaimDesk falls within Annex III. It is not clearly enumerated: (5)(a) addresses systems used by or on behalf of public authorities to evaluate eligibility for essential public assistance benefits, and (5)(c) addresses risk assessment and pricing for life and health insurance. A private administrator adjudicating employer-sponsored benefit claims sits between them; the open question under (5)(a) is whether Rockledge acts on behalf of a public authority. The register treats it as high-risk pending counsel determination, which is the conservative posture, and the Decision Memo presents both outcomes.
Not legal advice	EU AI Act tiering and obligations are stated for demonstration. Real applicability requires counsel.